

WGV_AUTH_0101 — Đăng nhập bằng Ví MetaMask / Login with MetaMask Wallet

Web3GiangVien · Layer: AUTH (L1 — Foundation)

Thuộc tính	Giá trị
Module Code	WGV_AUTH_0101
Version	v1.0
Ngày tạo	2026-05-20
Cập nhật	2026-05-20
Audience	Sinh viên, Giảng viên (mọi user của hệ thống)
Backend file(s)	backend/controllers/authController.js , backend/models/SinhVien.js , backend/models/GiangVien.js , backend/config/web3.js
Frontend file(s)	frontend/src/components/LoginPage.js , frontend/src/components/MetaMaskGuideModal.js , frontend/src/AuthContext.js , frontend/src/services/authService.js
Smart Contract	(Không ghi blockchain — chỉ dùng chữ ký off-chain)
API endpoint(s)	POST /api/auth/challenge · POST /api/auth/verify · POST /api/auth/logout
Yêu cầu MetaMask	☒ Bắt buộc

1. Tổng quan / Overview

Module này là **cổng vào duy nhất** của hệ thống Web3GiangVien. Hệ thống không dùng mật khẩu truyền thống — thay vào đó dùng **chữ ký số (signature)** từ ví MetaMask của bạn để chứng minh bạn là chủ ví. Sau khi xác thực thành công, server cấp một **JWT token** có hiệu lực 24 giờ để truy cập các chức năng tiếp theo.

Luồng quy trình / Process Flow (tóm tắt)



Phân biệt với module liên quan

Tiêu chí	AUTH_0101 (module này)	AUTH_0102 (Cập nhật profile)
Mục đích	Xác thực danh tính (login)	Bổ sung thông tin học vụ (GPA, kỹ năng, chuyên ngành)
Khi nào	Mỗi phiên làm việc	Lần đầu sau khi đăng ký
Bắt buộc	Mọi user	Sinh viên (để dùng được AI gợi ý đề tài)

2. Đường dẫn / Navigation

Chức năng	URL Frontend	Vai trò
Trang đăng nhập	<code>http://localhost:3000/</code> (mặc định)	Tất cả
Hướng dẫn cài MetaMask	Click “Chưa có ví? Hướng dẫn cài đặt” trên trang login	Tất cả
Đăng nhập bằng QR	Tab “QR Code” trên trang login	Tất cả (yêu cầu QR hợp lệ)
Dashboard sau login	<code>/dashboard</code>	Theo role (SV/GV/Admin)

3. Phân quyền / Access Rights

Vai trò / Role	Cách hệ thống nhận diện	Quyền sau khi login
Giảng viên (LECTURER_ROLE)	WalletAddress khớp record trong collection <code>GiangVien</code>	Tạo/duyet đề tài, chấm điểm, xem báo cáo SV
Sinh viên (STUDENT_ROLE)	WalletAddress khớp <code>SinhVien</code> , hoặc chưa khớp ai (auto-register)	Xem/đăng ký đề tài, nộp báo cáo, xem điểm
Admin	Cần seed thủ công qua script (<code>backend/seed_lecturer.js</code> hoặc tương đương)	Toàn quyền

⚠ **Quan trọng:** Giảng viên KHÔNG được phép tự đăng ký. Admin phải seed trước bằng script `node backend/seed_lecturer.js` (truyền địa chỉ ví + MaGV + HoTen + Email). Nếu giảng viên login bằng ví chưa seed → hệ thống tự tạo record SinhVien (sai role).

4. Hướng dẫn Chi tiết / Step-by-Step

4.1 Cài đặt MetaMask lần đầu — Vai trò: Sinh viên / Giảng viên

Khi nào dùng: Lần đầu tiên vào hệ thống và chưa từng cài extension MetaMask trên trình duyệt.

- Vào trang đăng nhập `http://localhost:3000/`
- Bấm link “Chưa có ví? Hướng dẫn cài đặt” (icon dấu hỏi) bên dưới nút Kết nối
- Đọc qua 5 bước trong modal “Hướng Dẫn Cài Đặt MetaMask”:
 - Bước 0: MetaMask là gì
 - Bước 1: Tải tại <https://metamask.io> → thêm extension vào trình duyệt (Chrome/Edge/Firefox/Brave)
 - Bước 2: Mở MetaMask → “Tạo một ví mới” → đặt mật khẩu mạnh (chỉ dùng cục bộ trên máy)
 - Bước 3: ⚠ **Cụm 12 từ khôi phục (Seed Phrase)** — viết ra giấy, KHÔNG chụp màn hình, KHÔNG lưu cloud
 - Bước 4: Hoàn tất → quay lại trang login
- Bấm “Đóng và Đăng nhập” để đóng modal

💡 **Lưu ý quan trọng về Seed Phrase:**

- 12 từ này = chìa khóa duy nhất khôi phục ví nếu mất máy
- Mất seed phrase = mất ví vĩnh viễn (không ai khôi phục được)
- Lộ seed phrase = hacker có thể ký xác thực thay bạn → chiếm tài khoản

4.2 Đăng nhập bằng MetaMask — Vai trò: Sinh viên / Giảng viên

Khi nào dùng: Mỗi lần bắt đầu phiên làm việc mới (token cũ hết hạn sau 24h).

1. Vào `http://localhost:3000/` → đảm bảo tab **"MetaMask"** đang được chọn (mặc định)
2. Bấm nút **"Kết Nối Ví MetaMask"** (màu cam, có icon Fox)
3. MetaMask popup hiện ra:
 - **Lần đầu:** Chọn account muốn dùng → bấm **"Next"** → **"Connect"** để cấp quyền cho site
 - **Lần sau:** Bỏ qua bước này nếu đã từng connect
4. MetaMask popup lần 2 — **yêu cầu ký chuỗi message:**

```
Hệ thống Web3 Giảng Viên

Thời gian: 2026-05-20T08:15:00.000Z
Nonce: a1b2c3d4
Ví: 0xAbC...123

Vui lòng ký thông báo này để xác thực.
```

→ Bấm **"Sign"** (đây KHÔNG phải giao dịch, KHÔNG tốn gas)

5. Đợi 1–2 giây → thấy thông báo **"Đăng nhập thành công! Đang chuyển hướng đến dashboard..."**
6. Hệ thống tự redirect đến `/dashboard` sau 2.5 giây

Fields gửi đi/nhận về (kỹ thuật)

API	Field	Mô tả	Bắt buộc	Loại	Ví dụ
POST <code>/api/auth/challenge</code> (request)	<code>walletAddress</code>	Địa chỉ ví Ethereum đang connect	✓	String (hex)	<code>0xAbC123...</code>
POST <code>/api/auth/challenge</code> (response)	<code>challengeId</code>	UUID cho phiên xác thực	—	UUID	<code>f47ac10b-...</code>
POST <code>/api/auth/challenge</code> (response)	<code>challenge</code>	Chuỗi cần MetaMask ký	—	String	(xem trên)
POST <code>/api/auth/verify</code> (request)	<code>challengeId</code>	UUID nhận từ bước trên	✓	UUID	<code>f47ac10b-...</code>
POST <code>/api/auth/verify</code> (request)	<code>signature</code>	Chữ ký MetaMask trả về	✓	String (hex)	<code>0xF12...</code>
POST <code>/api/auth/verify</code> (response)	<code>token</code>	JWT 24h, lưu localStorage key <code>authToken</code>	—	JWT String	<code>eyJhbGc...</code>
POST <code>/api/auth/verify</code> (response)	<code>user.role_id</code>	<code>LECTURER_ROLE</code> / <code>STUDENT_ROLE</code>	—	Enum	<code>STUDENT_ROLE</code>

💡 **Mẹo:** Challenge hết hạn sau **5 phút** kể từ lúc tạo. Nếu để MetaMask popup quá lâu rồi mới ký → phải thực hiện lại từ bước 2.

4.3 Đăng nhập bằng QR Code (tuỳ chọn) — Vai trò: Sinh viên

Khi nào dùng: Khi có QR code đã được hệ thống cấp sẵn (ví dụ trên thẻ sinh viên/email mời).

1. Mở tab “QR Code” trên trang login
2. Bấm “Quét Mã QR” → cấp quyền camera cho trình duyệt
3. Hướng camera vào mã QR → hệ thống tự nhận diện
4. Sau khi QR hợp lệ → vẫn yêu cầu MetaMask popup để ký xác thực (giống bước 4.2.4)
5. Đăng nhập thành công → redirect `/dashboard`

⚠ MetaMask vẫn cần: QR chỉ thay thế bước nhập wallet address ban đầu, KHÔNG bỏ qua bước ký chữ ký.

4.4 Đăng xuất — Vai trò: Mọi user

Khi nào dùng: Kết thúc phiên làm việc, hoặc đổi sang ví khác.

1. Từ trang Dashboard hoặc trang đã login lại → bấm nút “Đăng xuất”
2. Hệ thống xoá `authToken` khỏi `localStorage`
3. Redirect về trang login

💡 Lưu ý: Đăng xuất chỉ xoá session phía client. MetaMask vẫn nhớ đã từng connect site này — lần sau login lại sẽ nhanh hơn.

5. Quy tắc Nghiệp vụ / Business Rules

Rule ID	Quy tắc	Hệ quả khi vi phạm
BR-AUTH-01	<code>walletAddress</code> phải là địa chỉ Ethereum hợp lệ (<code>ethers.isAddress()</code>)	API 400 — "Invalid wallet address"
BR-AUTH-02	<code>signature</code> phải khớp với <code>walletAddress</code> đã đăng ký challenge	API 401 — "Invalid signature"
BR-AUTH-03	Challenge hết hạn sau 5 phút	API 400 — "Challenge expired" → phải request challenge mới
BR-AUTH-04	Mỗi <code>challengeId</code> chỉ dùng được 1 lần (xoá sau khi verify thành công)	Lần dùng thứ 2 → 400 expired
BR-AUTH-05	Wallet không có trong DB → tự động tạo SinhVien với MaSV/Email placeholder	Sinh viên mới có <code>DaCapNhatHoSo=false</code> → bắt buộc qua module AUTH_0102 trước khi dùng đầy đủ
BR-AUTH-06	JWT hết hạn sau 24 giờ (<code>expiresIn: '24h'</code>)	API trả 403 "Invalid token" → bắt login lại
BR-AUTH-07	So sánh wallet address không phân biệt hoa thường (luôn <code>.toLowerCase()</code>)	Phòng trường hợp Metamask đôi khi trả checksum address

6. Xử lý Lỗi Thường gặp / Error Handling

Lỗi (hiển thị)	Nguyên nhân	Cách xử lý
"Vui lòng cài đặt ví MetaMask để tiếp tục."	Extension chưa cài hoặc bị tắt	Bấm link "Hướng dẫn cài đặt" → cài tại metamask.io → reload trang
"Bạn đã từ chối yêu cầu kết nối."	User bấm "Reject" trên popup MetaMask (code 4001)	Bấm lại nút "Kết Nối Ví MetaMask" → chấp nhận
"Ví đã bị ngắt kết nối. Vui lòng kết nối lại."	User chuyển account trong MetaMask hoặc lock ví	Unlock MetaMask → login lại
"Invalid signature" (401)	Sai private key (đổi account sau khi nhận challenge)	Đảm bảo dùng đúng account ban đầu → request challenge mới
"Challenge expired" (400)	Để popup MetaMask quá 5 phút mới ký	Đóng popup → login lại từ đầu
"Invalid token" (403)	JWT hết hạn 24h hoặc bị sửa	Đăng xuất → đăng nhập lại
Trang trắng / không redirect /dashboard	Backend port 5000 hoặc Frontend port 3000 chưa chạy	Check <code>npm run dev</code> ở cả <code>backend/</code> và <code>frontend/</code>
MetaMask không hiện popup	Trình duyệt chặn popup hoặc MetaMask bị treo	Click vào icon MetaMask trên thanh extension → unlock ví

7. Tích hợp & Liên kết / Integration Points

Upstream (Đầu vào từ)	Downstream (Đầu ra đi đến)
MetaMask extension (chữ ký số ECDSA)	Mọi module cần <code>authMiddleware</code> (TOPIC, REG, REPORT, SCORE, BC...)
<code>frontend/src/services/authService.js</code> (<code>isMetaMaskInstalled</code> , <code>initializeProvider</code> , <code>getWalletAddress</code> , <code>authenticate</code>)	<code>frontend/src/AuthContext.js</code> → cung cấp <code>user</code> cho mọi component
(Nếu QR login) <code>apiService.validateQrForLogin()</code>	localStorage key <code>authToken</code> → đính vào header <code>Authorization: Bearer <token></code>

Chi tiết kỹ thuật:

- Middleware bảo vệ route:** `authController.authenticateToken` — gắn lên mọi endpoint cần đăng nhập (xem `server.js` dòng 87+)
- Verify chữ ký:** `web3Utils.verifySignature(message, signature, address)` trong `backend/config/web3.js` — dùng `ethers.verifyMessage()` để recover địa chỉ từ chữ ký rồi so sánh
- Lưu challenge tạm:** dùng `Map` in-memory tại `authController.js` — ⚠️ **không persistent** (mất khi restart server) → chỉ phù hợp môi trường dev/single-node. Production nên dùng Redis.

8. Câu hỏi Thường gặp / FAQ

? **Tôi không có tiền (ETH) trong ví, có login được không?** → Có. Bước login chỉ ký chuỗi message (off-chain), không phải giao dịch on-chain → không tốn gas. Bạn chỉ cần ETH khi thực hiện các thao tác ghi blockchain (ví dụ đăng ký đề tài chính thức, ghi điểm lên contract — xem module WGV_BC_0801).

? **Tôi là giảng viên nhưng login lại thấy mình là sinh viên?** → Wallet address của bạn chưa được seed vào collection `GiangVien`. Liên hệ admin chạy `node backend/seed_lecturer.js` với địa chỉ ví của bạn. Sau đó đăng xuất và đăng nhập lại.

? **Tôi đổi máy/đổi trình duyệt, có cần đăng ký lại không?** → Không. Chỉ cần import lại ví bằng 12 từ seed phrase vào MetaMask trên máy mới → login như bình thường. Hệ thống nhận diện bạn qua wallet address, không qua máy.

? **Lỡ ấn nhầm “Disconnect” trong MetaMask thì sao?** → Vào MetaMask → 3 chấm → “Connected sites” → kiểm tra `localhost:3000`. Hoặc đơn giản bấm lại “Kết Nối Ví MetaMask” trên trang login — popup connect sẽ hiện lại.

? **JWT hết hạn 24h, có cách nào kéo dài không?** → Hiện tại không có refresh token. Sau 24h phải login lại (ký lại chữ ký). Đây là thiết kế an toàn — nếu bị mất token thì attacker tối đa chỉ dùng được 24h.

? **Trang login hiển thị “Cổng Thông Tin Nhân Sự” — có phải sai project không?** → Đây là phần text UI còn sót từ template gốc trong `LoginPage.js`. Backend và logic xác thực vẫn đúng hệ thống Web3GiangVien (route `/api/auth/...` trả về role `LECTURER_ROLE` / `STUDENT_ROLE`). Có thể coi đây là TODO cập nhật label.

? **Có thể login bằng nhiều ví khác nhau cùng lúc không?** → Không trên cùng 1 tab. Mỗi tab giữ 1 `authToken` trong `localStorage`. Muốn dùng 2 tài khoản → mở tab ẩn danh (incognito) hoặc trình duyệt khác.

9. Quick Reference Card / Tóm tắt Nhanh

 In trang này để dán cạnh máy tính khi làm khóa luận

Tình huống	Thao tác	Vai trò
Lần đầu vào hệ thống	Cài MetaMask (metamask.io) → tạo ví → lưu 12 từ → bấm "Kết Nối Ví MetaMask" → ký challenge	SV / GV
Đăng nhập hàng ngày	Vào / → tab MetaMask → "Kết Nối" → "Sign" trên popup → vào dashboard	SV / GV
MetaMask không hiện popup	Click icon MetaMask trên thanh extension → unlock → bấm lại nút Kết Nối	SV / GV
Bị "Invalid signature"	Check đúng account đang chọn trong MetaMask (khớp ví đã request challenge)	SV / GV
Bị "Challenge expired"	Ký lại trong vòng 5 phút sau khi popup hiện	SV / GV
Đăng xuất	Bấm nút "Đăng xuất" trên dashboard	SV / GV
GV login lại thành SV	Liên hệ admin seed vào <code>GiangVien</code> collection bằng <code>seed_lecturer.js</code>	GV → Admin
Đổi máy mới	Import 12 từ seed phrase vào MetaMask trên máy mới → login bình thường	SV / GV

Tài liệu cho hệ thống Web3GiangVien — Khóa luận Kỹ sư Team_12.04.26 — Soạn theo skill

`SKILL_WEB3GIANGVIEN.md` v1.0